System and Organization Controls (SOC) 2 Type 2

SOC 2 Type 2 overview

System and Organization Controls (SOC) for Service Organizations are internal control reports created by the American Institute of Certified Public Accountants (AICPA). They're intended to examine services provided by a service organization so that users can assess and address the risk associated with an outsourced service.

A SOC 2 Type 2 attestation is performed under:

- SSAE No. 18, Attestation Standards: Clarification and Recodification, which includes AT-C section 105, *Concepts Common to All Attestation Engagements*, and AT-C section 205, *Examination Engagements* (AICPA, Professional Standards).
- SOC 2 Reporting on an Examination of Controls at a Service Organization Relevant to Security, Availability, Processing Integrity, Confidentiality, or Privacy (AICPA Guide).
- TSP section 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, 2017 Trust Services Criteria).

In addition, the Office 365 SOC 2 Type 2 attestation report addresses the requirements defined in the Cloud Security Alliance (CSA) Cloud Controls Matrix (CCM), and the Cloud Computing Compliance Criteria Catalogue (C5:2020) created by the German Federal Office for Information Security (BSI).

Office 365 SOC 2 attestations are based on rigorous comprehensive third-party examinations (also known as *audits*) conducted by an independent AICPA accredited CPA firm. At the conclusion of a SOC 2 audit, the auditor renders an opinion in a SOC 2 Type 2 report, which describes the cloud service provider's (CSP) system and assesses the fairness of the CSP's description of its controls. It also evaluates whether the CSP's controls are designed appropriately, were in operation on a specified date, and were operating effectively over a specified time period. Office 365 SOC 2 Type 2 reports are relevant to system Security, Availability, Processing Integrity, Confidentiality, and Privacy.

Microsoft in-scope cloud platforms and services

The Azure SOC 2 Type 2 attestation report shows Microsoft online services in scope:

- Azure (for detailed insight, see Microsoft Azure Compliance Offerings)
- Azure DevOps (see separate Azure DevOps SOC 2 Type 2 attestation report)

- Microsoft Dynamics 365 (for detailed insight, see Azure SOC 2 Type 2 attestation report)
- Microsoft Defender XDR
- Microsoft Defender for Cloud Apps
- Microsoft Defender for Endpoint
- Microsoft Defender for Identity
- Microsoft Forms Pro
- Microsoft Intune
- Microsoft Managed Desktop
- Microsoft Stream
- Microsoft Threat Experts
- Topics
- Nomination Portal
- Office 365, Office 365 U.S. Government, Office 365 U.S. Government - High, Office 365 U.S. Government Defense
- Power Apps
- Power Automate
- Power BI
- Copilot Studios
- Update Compliance

Azure, Dynamics 365, and SOC 2

For more information about Azure, Dynamics 365, and other online services compliance, see the Azure SOC 2 offering.

Office 365 and SOC 2

Office 365 environments

Microsoft Office 365 is a multi-tenant hyperscale cloud platform and an integrated experience of apps and services available to customers in several regions worldwide. Most Office 365 services enable customers to specify the region where their customer data is located. Microsoft may replicate customer data to other regions within the same geographic area (for example, the United States) for data resiliency, but Microsoft will not replicate customer data outside the chosen geographic area.

This section covers the following Office 365 environments:

- **Client software (Client)**: commercial client software running on customer devices.
- **Office 365 (Commercial)**: the commercial public Office 365 cloud service available globally.

- **Office 365 Government Community Cloud (GCC)**: the Office 365 GCC cloud service is available for United States Federal, State, Local, and Tribal governments, and contractors holding or processing data on behalf of the US Government.
- **Office 365 Government Community Cloud - High (GCC High)**: the Office 365 GCC High cloud service is designed according to Department of Defense (DoD) Security Requirements Guidelines Level 4 controls and supports strictly regulated federal and defense information. This environment is used by federal agencies, the Defense Industrial Base (DIBs), and government contractors.
- **Office 365 DoD (DoD)**: the Office 365 DoD cloud service is designed according to DoD Security Requirements Guidelines Level 5 controls and supports strict federal and defense regulations. This environment is for the exclusive use by the US Department of Defense.

Use this section to help meet your compliance obligations across regulated industries and global markets. To find out which services are available in which regions, see the International availability information and the Where your Microsoft 365 customer data is stored article. For more information about Office 365 Government cloud environment, see the Office 365 Government Cloud article.

Your organization is wholly responsible for ensuring compliance with all applicable laws and regulations. Information provided in this section does not constitute legal advice and you should consult legal advisors for any questions regarding regulatory compliance for your organization.

Office 365 applicability and in-scope services

Use the following table to determine applicability for your Office 365 services and subscription:

Expand table

Applicability	In-scope services
Commercial	Compliance Manager, Customer Lockbox, Delve, Exchange Online, Exchange Online Protection, Forms, Griffin, Identity Manager, Lockbox (Torus), Microsoft Teams, Microsoft Viva Topics, MyAnalytics, Office 365 Customer Portal, Office 365 Microservices (including but not limited to ObjectStore, Sway, PowerPoint Online Document Service, Query Annotation Service, School Data Sync, Siphon, Speech, eXtensible Application Program), Office Online, Office Services Infrastructure, OneDrive, Planner, Power Apps, Power Automate, Power BI, Project Online, Service Encryption with Microsoft Purview Customer Key, SharePoint Online, Windows 365
GCC	Compliance Manager, Delve, Exchange Online, Forms, Microsoft Defender for Office 365, Microsoft Entra ID, Microsoft Purview portal, Microsoft Teams, Microsoft Viva Topics, MyAnalytics, Office 365 Advanced Compliance add-on, Office Online, Office Pro Plus, OneDrive, Planner, Power Apps, Power Automate, Power BI, SharePoint Online, Stream, Windows 365

Applicability	In-scope services
GCC High	Exchange Online, Forms, Microsoft Defender for Office 365, Microsoft Entra ID, Microsoft Purview portal, Microsoft Teams, Office 365 Advanced Compliance add-on, Office Online, Office Pro Plus, OneDrive, Planner, Power Apps, Power Automate, Power BI, SharePoint Online, Windows 365
DoD	Exchange Online, Forms, Microsoft Defender for Office 365, Microsoft Entra ID, Microsoft Purview portal, Microsoft Teams, Office 365 Advanced Compliance add-on, Office Online, Office Pro Plus, OneDrive, Planner, Power BI, SharePoint Online

Office 365 audit reports

For links to audit documentation and reports, see the SOC section of the Service Trust Portal .

In accordance with AICPA requirements, you must have an existing subscription or free trial account in Office 365 or Office 365 U.S. Government to download SOC 1 and SOC 2 attestation reports and any bridge letters as needed.

Frequently asked questions

How often are Office 365 SOC reports issued?

Microsoft commissions a full SOC 1 Type 2 and SOC 2 Type 2 examination of Office 365 annually. The auditor's reports on these examinations (also known as audits) are issued as soon as they're ready after that audit. The SOC 3 report, which is based on the SOC 2 examination, is issued at the same time.

Because Microsoft doesn't control the investigative scope of the examination nor the timeframe of the auditor's completion, there's no set timeframe when these reports are issued. The reports are usually issued a few months after the end of the period under examination. Microsoft doesn't allow any gaps in the consecutive periods of examination from one examination to the next.

Microsoft also commissions a mid-year SOC 1 Type 1 and SOC 2 Type 1 examination of Office 365 for new Microsoft services that were issued since the last SOC Type 2 audit. Type 1 audits don't look back over a period of performance.

Due to the sophisticated nature of Office 365, the service scope is large if examined as a whole. This scope can lead to examination completion delays simply due to scale. Microsoft organizes all the examinations described above into two categories: Core Services and Microservices. Microsoft issues a report scoped to each examination.

SOC Type 2 audits examine a rolling 12-month *run window* (also known as audit period or more formally *period of performance*) with examinations conducted annually for the period October 1

through September 30 of the next calendar year. The examination starts promptly after the period of performance is complete.

Microsoft also issues *bridge letters* (also known as *gap letters*). These are self-attestations by Microsoft, not reports based on examinations by the auditor. Bridge letters are issued during the current period of performance that isn't yet complete and ready for audit examination. Microsoft issues bridge letters at the end of each quarter to attest to our performance during the prior three-month period. Due to the period of performance for the SOC type 2 audits, the bridge letters are typically issued in December, March, June, and September of the current operating period.

Where can I get the Office 365 SOC audit documentation including bridge letters?

For links to audit documentation, see the audit report section of the Service Trust Portal . You must have an existing subscription or free trial account in Office 365 or Office 365 U.S. Government to sign in. You can then download audit certificates, assessment reports, and other applicable documents to help you with your own regulatory requirements.

Where can I find an assessment of the Cloud Security Alliance CCM controls implementation?

Microsoft commissions an examination of Office 365 to be based on the American Institute of Certified Public Accountants (AICPA) Trust Services Principles and Criteria, including security, availability, confidentiality, and processing integrity, and the criteria in the Cloud Security Alliance (CSA) Cloud Controls Matrix (CCM).

The objective is to assess both the AICPA criteria and requirements defined in the CCM in one efficient inspection. The Office 365 SOC 2 Type 2 audit incorporates the CCM controls assessment as required by the CSA STAR attestation. For more information, see the Office 365 SOC 2 Type 2 attestation report.

Where can I see management responses to any exceptions noted?

Most examinations have some observations on one or more of the specific controls examined. This outcome is expected. Management responses to any exceptions are located towards the end of the SOC attestation report. Search the document for 'Management Response.'

Where can I see user entity responsibilities?

User entity responsibilities are your control responsibilities necessary if the system as a whole is to meet the SOC 2 control standards. These responsibilities are located at the very end of the SOC attestation report. Search the document for 'User Entity Responsibilities.'

Use Microsoft Purview Compliance Manager to assess your risk

Microsoft Purview Compliance Manager is a feature in the Microsoft Purview portal to help you understand your organization's compliance posture and take actions to help reduce risks. Compliance Manager offers a premium template for building an assessment for this regulation. Find the template in the **assessment templates** page in Compliance Manager. Learn how to build assessments in Compliance Manager.

Resources

- Service Trust Portal audit reports
- AICPA SOC for Service Organizations
- SSAE No. 18, Attestation Standards: Clarification and Recodification (AICPA Professional Standards)
- SOC 2 Reporting on an Examination of Controls at a Service Organization Relevant to Security, Availability, Processing Integrity, Confidentiality, or Privacy (AICPA Guide) (available for purchase)

Last updated on 04/09/2026